

Warsaw, the 12th
of November
2024

Decision

DKN.5131.9.2024

Pursuant to Article 104 § 1 of the Act of June 14, 1960, the Code of Administrative Procedure (Journal of Laws of 2024, item 572) in connection with Article 7(1) and (2), Article 60, Article 101, and Article 103 of the Act of May 10, 2018, on the Protection of Personal Data (Journal of Laws of 2019, item 1781), as well as Article 57(1)(a) and (h), Article 58(2)(d) and (i), Article 83(1) – (3), Article 83(4)(a) in connection with Article 24(1), Article 25(1), and Article 32(1) and (2), and Article 83(5)(a) in connection with Article 5(1)(f) and Article 5(2) of the Regulation of the European Parliament and of the Council (EU) 2016/679 of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (OJ EU L 119 of 4.05.2016, p. 1, OJ EU L 127 of 23.05.2018, p. 2, and OJ EU L 74 of 4.03.2021, p. 35), hereinafter referred to as Regulation 2016/679, after conducting an ex officio administrative proceeding regarding the violation of personal data protection regulations by X. in Y. (street (...), (...)), the President of the Personal Data Protection Office,

1. finds that X. in Y. (street (...), (...)) violated the provisions of Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679 by failing to apply appropriate technical and organizational measures to ensure a level of security appropriate to the risk of data processing using portable computers, in order to protect the personal data stored there, as well as documents containing personal data, including protection against accidental loss, destruction, or damage and disclosure to unauthorized persons;

a) appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of personal data processed using portable computers, which resulted in a violation of Article 5(1)(f) (principle of integrity and confidentiality) and Article 5(2) of Regulation 2016/679 (principle of accountability):

2. imposes on X. in Y. (street (...), (...)) for the violation of the provisions of Article 5(1)(f), Article 5(2), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679 an administrative fine in the amount of 24,555 Polish zlotys (in words: twenty-four thousand five hundred fifty-five zlotys),

3. orders X. in Y. (street (...), (...)) to bring its processing operations into compliance with the provisions of Regulation 2016/679 by implementing appropriate technical and organizational measures to ensure regular testing, measuring, and evaluating the effectiveness of technical and organizational measures intended to ensure the security of processing using portable computers, within 3 months from the date of delivery of this decision.

Justification

X. in Y. (street (...), (...)), hereinafter also referred to as X. or the Administrator, on May 17, 2023, reported to the President of the Personal Data Protection Office (hereinafter also referred to as the President of UODO or the supervisory authority) a personal data breach that occurred on May 14, 2023.

The reported personal data breach prompted the supervisory authority to assess the Administrator's fulfillment of its obligations arising from the provisions of Regulation 2016/679 regarding the proper safeguarding of data and the organization of the personal data protection system. In this regard, the President of UODO conducted an explanatory proceeding in this matter and subsequently initiated ex officio on May 15, 2024, an administrative proceeding regarding the possibility of X., as the data controller, violating obligations arising from the provisions of Article 5(1)(f), Article 5(2), Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679.

The President of UODO, as a result of the explanatory proceeding regarding the reported personal

data breach and the administrative proceeding, established the following factual state.

I. The personal data breach occurred as a result of the loss of a backpack in public transport (T.), which contained documents (invoices) and a laptop owned by X. In the personal data breach notification form, the Administrator indicated that it was unable to determine the approximate number of individuals whose data was breached. Consequently, the aforementioned event led to the loss of confidentiality of personal data. The Administrator indicated that the categories of personal data that were breached included: surnames and first names, parents' names, date of birth, bank account number, residential or temporary address, PESEL identification number, email address, data concerning earnings and/or owned assets, series and number of the identity card, phone number, health data, and others (membership in an association, official assignment). The Administrator specified the categories of individuals whose personal data were breached, stating that this data pertains to employees and children. The Administrator provided a detailed description of the categories of individuals, indicating that they were "(...) participants of the holiday, parents / legal guardians, contractors, members of W. performing the function of (...). In a letter dated February 1, 2024, the Administrator clarified the description of the scope of lost personal data, indicating that "(...) the following personal data were in paper documentation: data of individuals issuing invoices and individuals describing invoices - first names and surnames, job positions. On the laptop, the following personal data were present: downloaded scans of powers of attorney for (...) and treasurers (...) [first names, surnames, PESEL numbers of volunteers]; scans of invoices and letters [generally scans of correspondence including first names, surnames, and positions of correspondents with X.]; lists of contact data for (...) and other officials in (...) [titles, first names, surnames, phone numbers, email addresses, functions held]; documents concerning employees of X., e.g.: scans of maternity leave certificates; [first name, surname, address, PESEL]; team work plans - personal data of staff, [first names and surnames of members, age, title]; registration data for winter recreation for children and youth 2023 - [first names and surnames, parents' phone numbers, health status information, registered address]; bank statements - first names and surnames, account numbers, addresses (...)". In the aforementioned letter, X. also explained that the lost laptop was the property of the Administrator. Meanwhile, the person who lost the backpack - in which this laptop and paper documentation containing personal data were transported - was simultaneously a contractor of the Administrator and a person performing voluntary activities on behalf of the Administrator (this was an instructor of W.). The report of the personal data breach indicates that the matter of the lost backpack was reported to the Police. However, in the letter dated February 1, 2024, the Administrator indicated that "(...) X. did not receive any information from the Police. Despite the report, from verbal information obtained from officers at the station (...) it appeared that no proceedings would be initiated, as we are dealing with a loss rather than theft (...)".

II. Before the occurrence of the personal data breach, the Administrator conducted a risk analysis for the data processing operations in which the breach occurred. The Administrator provided the supervisory authority with a form of the relevant analysis in a .xlsx file format. According to X.'s explanations, the risk analysis was conducted regularly, and the analysis provided to the authority was performed in January 2023. The discussed document specified the following data processing activities: (...)

In the risk analysis in question - concerning the identified data processing activities - the following were specified, among others: - purpose of processing, - categories of individuals, - categories of data, - "general description of technical and organizational security measures in accordance with Article 32(1) (if possible)", - identified threats, - identified vulnerabilities, - probability and impact of breaches of accountability, integrity, and confidentiality, - risk expressed as a numerical value determined based on an adopted methodology, - risk level determined according to the adopted methodology (e.g., low or medium), - decision regarding the established risk, i.e., the manner of handling (actions) that risk, e.g., monitoring or acceptance, - justification of the decision regarding the adopted approach to risk, - possible consequences of the personal data breach.

In the conducted analysis within the framework of the "general description of technical and organizational security measures in accordance with Article 32(1)", the Administrator included, among

others, “password protection for computers”, “disk encryption in the case of taking equipment outside the premises”, “regular training on personal data protection”.

Among the identified threats, the Administrator indicated: sharing authentication data with unauthorized persons; hacking attacks, malware, ransomware; theft of equipment/documents; loss of equipment/documents; access by unauthorized persons to processed information.

Among the identified vulnerabilities, the Administrator indicated: gaps in applications; opening suspicious websites; taking documents/equipment outside the Administrator's premises; leaving computers/paper documentation unattended; inappropriate transportation of data carriers; lack of disk encryption.

In the submitted analysis for individual processing activities, the Administrator assigned a risk level and indicated what decision was made regarding that risk. The justification for the decision was also presented, stating: “(...) The application of the adopted data processing principles ensures sufficient protection of the data. User awareness regarding the safe processing of personal data must be continuously raised. (...)”. Along with the risk analysis, the administrator provided the methodology for assessing the risk level, stating in this document that “(...) risk assessment includes risk analysis and risk evaluation. Risk evaluation, i.e., determining which risks are acceptable by comparing the established risk levels with those that can be accepted (...)”. In the discussed methodology, the Administrator defined the concepts of accountability, integrity, and confidentiality. Accountability was defined as “compliance with all principles in the processing of personal data and the ability to demonstrate compliance”, integrity was defined as “any changes made in IT systems and on paper documents containing personal data were the result of planned actions by users; a property ensuring that data has not been altered or destroyed in an unauthorized manner”, while confidentiality was defined as “ensuring that personal data is not disclosed to unauthorized entities”.

III. After the occurrence of the personal data breach (on May 17, 2023), the Administrator conducted a risk analysis for the operations...

data processing, within which the subject violation occurred. The Administrator provided the supervisory authority with a form of the analysis in a .xlsx file format. The risk analysis conducted after the occurrence of the personal data breach essentially overlaps with the risk analysis performed before the breach.

The following changes were introduced in the discussed document:

- In the section regarding identified vulnerabilities, the Administrator added that improper transportation of data carriers also pertains to leaving them in public transport,
- In the section concerning the justification of decisions regarding specific risks, it was additionally indicated: “(...) As a result of the breach that occurred on May 14, 2023, a decision was made to conduct a detailed verification regarding the encryption of disks on company computers taken outside the Administrator's premises (...)”.

IV.X. presented evidence regarding the technical and organizational measures whose implementation was intended to ensure a level of security corresponding to the risk of violation of the rights or freedoms of individuals whose data the Administrator processes. In this regard, the Administrator provided explanations concerning the procedure for taking portable computers and documents containing personal data outside the area of personal data processing. By letter dated May 19, 2023, the supervisory authority requested X. to indicate whether the Administrator had developed and implemented a procedure for taking portable computers and documents containing personal data outside the area of personal data processing, and if so, requested a copy of it and information on whether and how compliance with it is verified by the Administrator's employees. In response to the above question in a letter dated May 30, 2023, the Administrator indicated that “(...) in W. [which encompasses the entire organization including X.], among other things, the Instruction (...) [attachment] has been adopted, which specifies the security of digital data and requirements for IT infrastructure, including specifying (...). The Instruction is available on the W. intranet (...) and was adopted by resolution (...). According to the Statute (...) every member of W. is obliged to comply with the resolutions of the authorities of W., including adopted regulations and instructions. W. has a system of penalties for violating the Statute (...) or internal regulations. The Procedure (...) [attachment]

also applies in W. The Procedure is available on the W. intranet for every member of W. [screen]. The procedure specifies detailed rules for storing and transporting documents in both paper and electronic form. Both of the above documents are mentioned in the Policy (...).

In December 2023, there was a change in the authorities of X. [general meeting of the association]. The new (...) after getting acquainted with the current affairs of the organization, after the protocol handover, X. began visits [audits] in each (...) to check the correctness of the functioning (...), including the correctness of personal data processing, application of security measures, and implementation of adopted procedures. The visit to (...) concerning the breach was scheduled for June 2, 2023. The person responsible for the breach had been trained in personal data protection (...)” [original spelling].

The document “Procedure (...)” (hereinafter also referred to as the “Procedure”) contains provisions regarding the processing of personal data by persons authorized by the Administrator. At the beginning of this document, it is indicated that “(...) below we provide a short list of skills that every instructor should possess. With its help, you can conduct a self-assessment and determine directions for self-education in the field of personal data protection. The instructor: - Knows what personal data and its processing are, and can identify personal data processing operations in their daily instructional service (...) - Knows the specific rules for the security of personal data while in the field (...)”. The discussed document also contains indications regarding the handling of personal data contained in paper documentation. The Procedure states: “(...) do not take documentation containing personal data, including ad hoc copies or printouts, outside the premises occupied by W. without prior consent from the data protection officer, unless: - you are going to court, an office, etc. for business purposes, for which these documents are necessary, - you are going on a camping trip or another form of recreation for children and youth (...)”.

The Procedure also specifies the “Principles (...)” (Chapter (...)). Within this chapter, among other things, the “Principles (...)” are defined, where the necessity of not leaving such carriers unattended and under supervision and the necessity of using device encryption are emphasized (detailed factual findings regarding the application of encryption mechanisms are discussed in point V of the factual justification). In Chapter (...) of the Procedure “Specific (...)”, the necessity of ensuring an appropriate level of security is emphasized in situations where personal data carriers are taken outside the Administrator's organization headquarters. This chapter contains a table indicating threats and “proposals for action”. The threats specified therein are related to the subject breach of personal data protection, and within the “proposals for action”, attention is drawn to the necessity of not leaving data carriers without supervision by persons authorized to process them. In Chapter (...) of the Procedure, it is also noted that “(...) the above remarks regarding paper documentation containing personal data also apply to electronic carriers of such data (...)”.

In turn, in the “Instruction (...)” (hereinafter also referred to as the “Instruction”), it was established, among other things, that “(...) all data generated in connection with the activities of W. in electronic form should be secured in an appropriate IT system approved by W.. Data recorded on local devices may...

only constitute a working copy of the data, and their storage on private or company devices requires compliance with the requirements described in the further part of the Instructions (...)” and that “(...) the IT infrastructure must be secured against physical access by unauthorized persons (...)”.

V. The Administrator provided the supervisory authority with detailed explanations regarding the encryption of the hard drive of the lost laptop. In the “Instructions (...)” it was indicated that “(...) in the case of company devices taken outside the buildings of W., it is mandatory to enable storage encryption of the device (...)”. Meanwhile, in the “Procedure (...)” within the framework of the “Principles (...)” it was specified that “(...) Personal data that is on such [i.e., taken outside the headquarters of the Administrator organization – note of the President of UODO] media must be encrypted with a password protecting the entire device (...)”. In a letter dated May 30, 2023, the Administrator indicated that “(...) the computer did not have disk encryption (...)”.

The Administrator's awareness of the necessity of using disk encryption on portable computers used

for processing personal data outside its headquarters also stems from the communications provided to the supervisory authority by the data protection officer. The communications were issued after the occurrence of the data protection breach in question, but they indicate the requirements established by the Administrator regarding disk and portable memory encryption. In the communication dated August 11, 2023, the Data Protection Officer W. indicated that "(...) if documents must be stored on the computer's hard drive, disk encryption should be applied or alternatively, the folders containing the documents should be encrypted. Files can also be encrypted directly. I am attaching a brief guide on file and folder encryption (...)". In another communication dated February 7, 2024, the Data Protection Officer W. pointed out the decisions of the President of UODO imposing administrative fines, in which the issue of using encryption on storage media was raised. In this communication, the Data Protection Officer W. recommended, among other things, "(...) the implementation of procedures from the Policy (...) related to disk and portable memory encryption (...)".

Moreover, the Administrator's awareness of the necessity of applying additional security measures for computer equipment when taken outside the headquarters of X. arises from the "audit surveys" for the years 2023 and 2024 (the completed surveys were delivered to the supervisory authority along with a letter dated May 22, 2024). In the survey conducted before the occurrence of the data protection breach in question (the audit was conducted on April 11, 2023), there is a question regarding the removal of company equipment outside the unit, to which an affirmative answer was given. In the section of the survey designated as "comments/identified irregularities," it was indicated that "(...) in part of the computers, the lack of disk encryption was noted. X. is in the process of replacing equipment and implementing new equipment that includes disk encryption software. Employees and collaborators have been informed that equipment without disk encryption should not be taken outside the headquarters (...)".

VI. The Administrator provided explanations regarding the testing, measuring, and assessing the effectiveness of technical and organizational measures that were supposed to ensure the security of personal data processing. In a letter dated February 1, 2024, the Administrator emphasized that X. is a non-governmental organization that largely bases its current activities on services provided by volunteers. The Administrator indicated that "(...) it takes all possible measures to carry out its activities safely. Twice a year, we conduct an audit of computer equipment with the help of volunteers with IT education. Based on its results, we develop a list of tasks for action, e.g., implementing additional security measures, changing equipment. These actions are implemented according to priorities and financial capabilities. X. purchased computer equipment after this breach that enables disk encryption on company equipment. Equipment that does not have encryption capabilities has been withdrawn from use. Additionally, the Administrator performs regular backups, which are tested by the person responsible for the IT area. Volunteers with education and experience in IT support the Administrator in monitoring the security aspects of equipment and IT systems (...)".

X. supplemented its explanations regarding the aforementioned obligation of the data administrator on May 22, 2024. X. indicated that its actions in this discussed area concerned: "Policies and procedures", "Access control", "Regular audits and reviews", "Conducting risk and threat analysis", "Performing backups and testing them". As part of the actions defined by the Administrator as "policies and procedures," X. indicated that: 1) it adopted the "Policy (...)", which is subject to reviews and updates. The Administrator explained that reviews are conducted during annual audits carried out by the Data Protection Officer, 2) "(...) the Administrator issues instructions for processing personal data, in which each authorized person declares that they commit to appropriately securing personal data and are familiar with the adopted procedures. The issued instructions for processing personal data are subject to assessment during regular audits [the scope of instructions is examined, whether all persons authorized to process personal data have been issued instructions] (...)", 3) "(...) Employees, collaborators, and volunteers during regular briefings that took place.

the fact that X. was responsible for determining the purposes and means of processing personal data in connection with its statutory activities, thus establishing itself as the data controller in this case, in accordance with the definition provided in Article 4(7) of Regulation 2016/679.

II. Violation of the provisions of Article 5(1)(f), Article 5(2), Article 24(1), Article 25(1), and Article 32(1) and (2) of Regulation 2016/679.

Initially, it should be noted that in this case, the data controller is X., as according to Article 4(7) of Regulation 2016/679, "controller" means the natural or legal person, public authority, agency, or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data; where the purposes and means of such processing are determined by Union law or the law of a Member State, the controller may be designated by Union law or the law of a Member State or specific criteria for its designation may be laid down.

According to § (...) of the Statute (...), hereinafter referred to as the Statute of W., W. is a community of basic and territorial organizational units (paragraph 1). The territorial organizational units of W. are (...) (paragraph 2). Furthermore, § (...) paragraph 2 of the Statute of W. states that X. has legal personality. The discussed statute indicates that X. creates conditions for the operation of (...) and subordinate organizational units by: (...).

As evidenced by the collected evidence, the lost laptop was the property of X., and the documents found in the backpack were generated in connection with its activities.

From the above facts, it follows that X. determined the purposes and means of processing personal data for the needs related to its statutory activities, and therefore, in this case, X. is the data controller, in accordance with the definition contained in Article 4(7) of Regulation 2016/679. This is further confirmed by the fact that the key explanations provided by the Administrator are logical, coherent, and correlate with the entirety of the evidence collected.

In this factual context, after reviewing all the evidence gathered in the case, the President of the Personal Data Protection Office considered the following.

the necessity for the administrator to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk. The regulation emphasizes that the measures taken should be proportionate to the risks associated with the processing of personal data.

The document submitted to the supervisory authority regarding the notification of a personal data breach indicates that the full name of the administrator is "X." According to Article 34 of the Personal Data Protection Act (u.o.d.o.), the President of the Personal Data Protection Office (UODO) is the competent authority regarding data protection and the supervisory authority within the meaning of Regulation 2016/679.

Pursuant to Article 57(1)(a) and (h) of Regulation 2016/679, without prejudice to other tasks specified under this regulation, each supervisory authority monitors and enforces the application of this regulation within its territory and conducts proceedings regarding breaches of this regulation, including based on information received from another supervisory authority or another public authority.

Article 5 of Regulation 2016/679 sets forth principles regarding the processing of personal data that must be respected by all administrators, i.e., entities that determine the purposes and means of processing personal data either alone or jointly with others. According to Article 5(1)(f) of Regulation 2016/679, personal data must be processed in a manner that ensures appropriate security of personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ("confidentiality and integrity"). Furthermore, according to Article 5(2) of Regulation 2016/679, the administrator is responsible for compliance with the provisions of paragraph 1 and must be able to demonstrate compliance ("accountability"). The specifics of the confidentiality principle referred to in Article 5(1)(f) of Regulation 2016/679 are further detailed in the provisions of this legal act.

According to Article 24(1) of Regulation 2016/679, taking into account the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying likelihood and severity, the administrator implements appropriate technical and organizational measures to ensure that processing is performed in accordance with this regulation and to be able to demonstrate this. These measures are reviewed and updated as necessary.

In accordance with Article 25(1) of Regulation 2016/679, taking into account the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying likelihood and severity arising from processing, the administrator—both when determining the means of processing and during the processing itself—implements appropriate technical and organizational measures, such as pseudonymization, designed to effectively implement data protection principles, such as data minimization, and to provide necessary safeguards for processing to meet the requirements of this regulation and protect the rights of data subjects.

From the content of Article 32(1) of Regulation 2016/679, it follows that the administrator is obliged to apply technical and organizational measures corresponding to the risk of infringement of the rights and freedoms of natural persons with varying likelihood and severity of threat. The provision specifies that when deciding on technical and organizational measures, consideration must be given to the state of technical knowledge, the cost of implementation, the nature, scope, context, and purposes of processing, and the risk of infringement of the rights or freedoms of natural persons with varying likelihood and severity. The cited provision indicates that determining appropriate technical and organizational measures is a two-step process.

Firstly, it is essential to determine the level of risk associated with the processing of personal data, taking into account the criteria indicated in Article 32(1) of Regulation 2016/679, and then to establish what technical and organizational measures will be appropriate to ensure a level of security commensurate with that risk.

These determinations, where appropriate, should include measures such as pseudonymization and encryption of personal data, the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services, the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident, and regular testing, measuring, and evaluating the effectiveness of technical and organizational measures to ensure processing security. According to Article 32(2) of Regulation 2016/679, when assessing whether the level of security is appropriate, the administrator takes into account, in particular, the risks associated with processing, especially those arising from accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or unauthorized access to personal data transmitted, stored, or otherwise processed.

As indicated in Article 24(1) of Regulation 2016/679, the nature, scope, context, and purposes of processing as well as the risk of infringement of the rights or freedoms of natural persons with varying likelihood and severity are factors that the administrator is obliged to consider in the process of building a data protection system, particularly in light of the other obligations specified in Article 25(1), Article 32(1), or Article 32(2) of Regulation 2016/679. The indicated provisions specify the confidentiality principle defined in Article 5(1)(f) of Regulation 2016/679, and adherence to this principle is necessary for the proper implementation of the accountability principle resulting from Article 5(2) of Regulation 2016/679.

One of the legal bases for the protection of personal data introduced by Regulation 2016/679 is the obligation to ensure the security of processed data, specified, among others, in Article 32(1) of Regulation 2016/679. This provision introduces a risk-based approach, while also indicating the necessity for the administrator to implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk.

****Criteria on the Basis of Which the Administrator Should Select Appropriate Technical and Organizational Measures to Ensure a Level of Security Corresponding to the Risk****

In addition to the risk of infringement of the rights or freedoms of natural persons, the state of technical knowledge, the cost of implementation, and the nature, scope, context, and purposes of processing must also be taken into account.

Regulation 2016/679 introduced an approach in which risk management is the foundation of activities

related to the protection of personal data and is characterized as a continuous process. Data processors are obliged not only to ensure compliance with the guidelines of the aforementioned regulation through a one-time implementation of organizational and technical security measures but also to ensure the continuity of monitoring the level of threats and to provide accountability regarding the level and adequacy of the implemented safeguards. This means that it becomes necessary to demonstrate to the supervisory authority that the solutions implemented to ensure the security of personal data are adequate to the level of risk and also take into account the nature of the organization and the mechanisms used for processing personal data. The administrator must independently conduct a detailed analysis of the data processing processes and assess the risk, and then apply such measures and procedures that will be adequate to the estimated risk. The consequence of such an orientation is the abandonment of lists of requirements regarding security imposed by the legislator in favor of independently selecting safeguards based on a threat analysis. Administrators are not provided with specific measures and procedures regarding security.

In light of the above, it should be noted that the risk analysis conducted by the data administrator should be documented and justified primarily based on the determination of the factual state existing at the time of its conduct. It is necessary to take into account, in particular, the characteristics of the processes taking place, assets, vulnerabilities, threats, and existing safeguards within the framework of the ongoing processes of personal data processing. It is also essential not to overlook the scope and nature of the personal data processed during the activities carried out by the data administrator, as the potential negative consequences for the individual in the event of a breach of their personal data protection will depend on the scope and nature of the disclosed data.

To ensure that the risk analysis is conducted appropriately, threats that may arise in the data processing processes should be defined for each of the assets. The term "asset" is used to indicate everything that constitutes value for the data administrator. Certain assets will represent a higher value than others and should also be assessed and safeguarded from this perspective. The interconnections of the existing assets are also very important, e.g., the confidentiality of assets (personal data) will depend on the type and manner of processing that data.

Determining the value of assets is necessary to estimate the consequences of a potential incident (breach of personal data protection). It is obvious that a wide range of personal data or the processing of personal data referred to in Article 9 or Article 10 of Regulation 2016/679 may cause far-reaching negative consequences for the individuals concerned in the event of a breach of personal data protection, so they should be assessed as high-value assets, and consequently, the level of their protection should be appropriately high.

Determining existing or applied safeguards is necessary, among other things, to avoid duplicating them. It is also imperative to verify the effectiveness of these safeguards, as the existence of an untested safeguard may first eliminate its value, and second, may create a false sense of security and may result in the omission (failure to detect) a critical vulnerability that, if exploited, could have very negative consequences, including, in particular, leading to a breach of personal data protection.

A vulnerability is commonly defined as a weakness or gap in security that, if exploited by a given threat, can disrupt operations and may also lead to incidents or breaches of personal data protection. Identifying threats involves determining what threats may arise and from what direction (cause).

One method of conducting a risk analysis is, for example, defining the level of risk as the product of the probability and consequences of a given incident occurring. A risk matrix is typically used, which allows visual representation of risk levels, presenting the levels of risk for which the organization defines appropriate actions.

The necessity of conducting a risk analysis is also emphasized in case law. In this regard, the Administrative Court in Warsaw stated, among other things, in its judgments of May 13, 2021, case file II SA/Wa 2129/20, and October 5, 2023, case file II SA/Wa 502/23, that "the data administrator should therefore conduct a risk analysis and assess what threats they are dealing with." The Administrative Court in Warsaw, in the justification of its judgment of August 26, 2020, case file II SA/Wa 2826/19

(upheld by the Supreme Administrative Court in its judgment of February 28, 2024, case file III OSK 3839/21), indicated that "(...) This provision [Article 32 of Regulation 2016/679] does not require the data administrator to implement any technical and organizational measures that are to constitute personal data protection measures, but requires the implementation of adequate measures. Such adequacy should be assessed based on...

the manner and purpose for which personal data is processed, but it is also necessary to take into account the risks associated with the processing of such personal data, which may vary in magnitude. The adopted measures must be effective; in specific cases, some measures will need to be aimed at mitigating low risk, while others must mitigate high risk. However, it is important that all measures (as well as each one individually) are adequate and proportional to the level of risk (...)

technical-organizational actions fall within the responsibility of the personal data controller, but they cannot be selected in a completely arbitrary and voluntary manner, without considering the level of risk and the nature of the protected personal data (...). Furthermore, in the judgment of October 5, 2023, case reference II SA/Wa 502/23, the Administrative Court in Warsaw stated that "the supervisory authority is not obliged to indicate to the Controller the technical and organizational solutions that it should implement to ensure that the processing of personal data is carried out in accordance with the law. It is the responsibility of the Controller to implement these measures and then, if necessary, demonstrate that it complies with the principles of personal data processing specified in Regulation 2016/679, in accordance with the principle of accountability (Article 5(2) of the aforementioned regulation)."

Referring the above considerations to the factual state of the case at hand, it should be noted that if the Controller allowed the possibility of using computer equipment (on which personal data is processed) and taking paper documentation containing personal data outside the processing area, then for the proper fulfillment of the obligations arising from the aforementioned provisions of Regulation 2016/679, it should first conduct a risk analysis and based on it determine and implement adequate measures ensuring security in the process of personal data processing. This analysis should indicate the risks associated with the aforementioned actions of processing personal data and should foresee appropriate security measures to minimize the risk of a breach of personal data protection. In the discussed case, conducting such an analysis was particularly important due to the specific nature of the functioning of the organization known as X. and the nature of the tasks performed by the instructors of this organization.

The circumstances mentioned above, due to the necessity of adopting solutions regarding the processing of personal data, should lead to the undertaking of a series of specific actions ensuring the security of personal data. The starting point for determining these actions should be – which must be emphasized again – conducting a risk analysis. In this analysis, the Controller should identify the possibility of loss of access (e.g., as a result of theft or loss) to paper documentation and to the computer equipment used for processing personal data outside the premises of its organization, and consequently identify the possibility of breaching the confidentiality of personal data contained on this equipment and in these documents.

It should also be noted that the obligation to implement appropriate technical and organizational measures to provide the necessary safeguards for processing, given the adopted manner of processing personal data, also arises directly from Article 25(1) of Regulation 2016/679. This provision requires the data controller to take data protection into account, particularly at the design phase. This implies that the Controller – by allowing the use of portable computers outside the premises of its organization by authorized persons and permitting these persons to take documents containing personal data – should already at this stage determine (and implement) appropriate security measures.

The gathered evidence indicates that the Controller conducted a risk analysis both before and after the occurrence of the personal data breach. In the risk analysis conducted in January 2023 (i.e., before the personal data breach), the Controller anticipated risks associated with the theft or loss of computer equipment or documents containing personal data. A detailed description of the risks relevant to this

case can be found in the factual justification (see point II of the factual justification). The Controller was aware of the existing threats and assessed the likelihood of their occurrence, from the perspective of accountability, integrity, and confidentiality of personal data (the manner in which the Controller defined "accountability," "integrity," and "confidentiality" is described in point II of the factual justification).

The Controller also identified vulnerabilities whose occurrence leads to breaches of personal data protection. Among the identified vulnerabilities, X. included, for example, leaving data carriers without proper supervision or inappropriate transportation of them. Moreover, the Controller considered a vulnerability in the form of "lack of disk encryption" (it should be assumed that the Controller meant the disks of those devices on which personal data is processed). The Controller assessed – according to its adopted methodology – the level of risk and the manner of dealing with that risk, as well as justified why it made such a decision.

It should be noted that for the processing activities of personal data (included in the discussed risk analysis), the Controller made a decision to accept or monitor the level of risk, justifying this decision in the following way: "(...) The application of the adopted data processing principles ensures sufficient protection of the data. User awareness regarding the safe processing of personal data should be continuously raised (...)" or

"(...) The application of the adopted data processing principles ensures sufficient data protection. Users' awareness regarding the secure processing of personal data must be continuously raised, including reminders about the principle of storing electronic documents in the cloud (...)".

In the factual state of the case at hand, the risk of violating personal data protection concerned the threat associated with the loss or theft of a laptop and paper documentation. The administrator used these data carriers for processing personal data outside the premises of his organization. It should be noted that regarding portable computers taken outside the administrator's organization – due to the associated threats – in order to counteract potential consequences of violations and to prevent the loss of confidentiality of personal data contained on such devices, the administrator, in accordance with the aforementioned provisions of Regulation 2016/679, is obliged to implement adequate safeguards in the form of, for example, encrypting the hard drives of the computer. The determination of these appropriate safeguards should result from a risk analysis conducted after proper identification of threats to personal data processed using portable computers used outside the administrator's organization.

It should be pointed out that the Regional Administrative Court in Warsaw also expressed its opinion on this matter, which in its judgment of January 19, 2021, case file II SA/Wa 702/20, stated that "(...) the data administrator should adequately secure personal data against accidental loss using appropriate technical and organizational measures. Personal data should be processed in a manner that ensures their appropriate security and confidentiality, including protection against unauthorized access to them and to the equipment used for their processing, as well as against unauthorized use of such data and such equipment (recital 39 of Regulation 2016/679)".

It is also worth citing the judgment of the Supreme Administrative Court of July 5, 2024, case file III OSK 2654/22, where it was stated that "(...) the administrator was obliged to implement appropriate technical and organizational measures to ensure a level of security commensurate with that risk. The implementation of such measures should be understood as the introduction of safeguards that will be adequate to the accepted risk, thus preventing violations of the principles of personal data processing under normal conditions. In the realities of this case, it was therefore not about preventing the loss of carriers with personal data, but about preventing their disclosure in the event of such loss."

From the risk analysis submitted by X., it follows that the Administrator, being aware of the risk associated with the loss of computer equipment taken outside the premises of his organization, assessed this risk as acceptable (or monitored), and within the framework of the approach to this risk, defined the safeguards that should be implemented to maintain the level he specified. The evidence gathered in this case indicates that when assessing the level of risk, the Administrator took into

account that computers taken outside the premises of his organization are secured by means of disk encryption (cf. point II of the factual justification). This follows not only from the risk analysis but also from other regulations applicable to the Administrator, which stipulate that in the case of taking computers outside the premises of his organization, the storage of these devices should be encrypted (cf. point V of the factual justification).

As indicated by the gathered evidence, the Administrator received signals regarding the necessity to implement specific solutions in the case of processing personal data using portable computers. Before the occurrence of the personal data breach in question, an audit was conducted, which indicated the necessity for X. to implement disk encryption on computers taken outside the premises of her organization, and in the case of non-implementation of encryption, in accordance with the recommendations indicated in the audit, the computers should not be taken outside the Administrator's premises.

Despite the fact that the Administrator correctly identified the threats in the case of processing personal data using portable computers and using paper documentation taken outside his organization, and also defined the level of risk of violating this data and specified the approach to risk by indicating the safeguards that should be applied, he did not, however, take the actions he himself envisaged, and in particular, did not initiate the encryption of the storage of computers taken outside the premises of his organization (cf. point V of the factual justification).

Continuing the considerations regarding security measures, it should be remembered that the role of the administrator is not limited to a one-time development and implementation of organizational and technical measures aimed at ensuring the processing of personal data in accordance with the principles expressed in Regulation 2016/679. The necessity for ongoing verification of the adequacy of these measures is particularly important in the case of processing personal data outside the area of the Administrator's organization.

In the event of an incident such as that which occurred in this case (loss of carriers of personal data), it is very important to analyze the correctness of the Administrator's compliance with his obligation arising from Article 32(1)(d) of Regulation 2016/679, i.e., regular testing, measuring, and assessing the effectiveness of technical and organizational measures aimed at ensuring the security of processing.

Regular testing, measuring, and assessing the effectiveness of technical and organizational measures aimed at ensuring the security of processing is a fundamental obligation of every administrator.

****1. Subject of Processing Resulting from Article 32(1)(d) of Regulation 2016/679****

The Administrator is therefore obliged to verify both the selection and the level of effectiveness of the technical measures used at every stage of processing. The complexity of this verification should be assessed in terms of adequacy to risks and proportionality in relation to the state of technical knowledge, costs of implementation, and the nature, scope, context, and purposes of processing. Testing, measuring, and evaluating, in order to fulfill the requirement resulting from Article 32(1)(d) of Regulation 2016/679, must be conducted regularly, consciously planned, organized, and documented (in connection with the principle of accountability - Article 5(2) of Regulation 2016/679) within specified time intervals, regardless of changes in the organization and the course of data processing processes.

New risks or threats may materialize or be revealed spontaneously, in a manner completely independent of the administrator, and this is a fact that should also be taken into account both when building a personal data protection system and during its implementation. This, in turn, defines the necessity of conducting regular verification of the entire personal data protection system in terms of both adequacy and effectiveness of the implemented organizational and technical solutions. The assessment of the probability of a given event occurring should not be based solely on the frequency of events in a given organization, as the fact that a particular event did not occur in the past does not mean that it cannot occur in the future.

The necessity for the Administrator to fulfill the discussed obligation was also pointed out by the Administrative Court in Warsaw, which in its judgment of October 21, 2021, case file II SA/Wa 272/21,

indicated that “(...) the President of the UODO was also correct in stating in the justification of the contested decision that the lack of regulations in the procedures adopted by the Company ensuring regular testing, measuring, and evaluating the effectiveness of the technical and organizational measures applied to ensure data processing security contributed to the occurrence of a personal data breach. The authority also rightly points out that it was demonstrated in the proceedings that the Company did not conduct tests aimed at verifying the security of the application (...) and the WebAPI of the system (...), concerning the vulnerability of the IT system related to the occurrence of a personal data breach (...) conducting tests only in the event of an emerging threat, without introducing a procedure that would define a schedule of actions ensuring regular testing, measuring, and evaluating the effectiveness of the implemented measures is insufficient. The Company, as evidenced by the collected material, despite the adopted solutions, was unable to detect vulnerabilities due to the lack of regular tests of the system implemented by the Company (...) Therefore, it is impossible in this context to challenge the assessment of the President of the UODO that regular testing, measuring, and evaluating the effectiveness of technical and organizational measures aimed at ensuring the security of processing is a fundamental obligation of every administrator and processor resulting from Article 32(1)(d) of the GDPR (...)”. In turn, in the judgment of June 6, 2023, case file II SA/Wa 1939/22, the Administrative Court in Warsaw indicated that “(...) the obligation to regularly test technical and organizational measures to secure the processing of personal data, in order to ensure a level of security corresponding to this risk, in the sense of Article 32(1) introductory sentence of the GDPR, arises directly from the wording of point (d) of the indicated Article 32(1), while the obligation to document actions in this regard is established by the principle of accountability (Article 5(2) of the GDPR)”. The Administrative Court in Warsaw expressed a similar view in its judgment of June 21, 2023, case file II SA/Wa 150/23.

As evidenced by the collected evidence, the Administrator took actions regarding testing, measuring, and evaluating the effectiveness of the technical and organizational measures aimed at ensuring security (cf. point VI of the factual justification), but these actions did not lead to effective limitation of the negative impact of the vulnerability that contributed to the personal data breach. The regulations adopted by the Administrator assumed the necessity of applying additional safeguards in the case of using portable computer equipment outside the headquarters of X.. The verification process of the security measures, with particular attention to the use of encryption of storage media taken outside the organization’s headquarters, proved ineffective. The result of the lack of appropriate action (i.e., adequate to the level of risk assessed by X.) in this regard was the materialization of the identified threat in the form of losing a backpack in public transport, which contained paper documents with personal data and a computer with personal data, on which appropriate safeguards were not applied to protect this data. This resulted in a breach of the confidentiality of personal data, which the Administrator itself indicates in the notification of the personal data breach (cf. point I of the factual justification).

The President of the UODO recognizes that in this case we are dealing with an emergency and extraordinary event, namely the loss of personal data carriers. However, assuming that the laptop would have been secured in accordance with the recommendations presented in the risk analysis and in the internal regulations of X., the situation would have been completely different – at least in this aspect related to the processing of personal data located on the portable computer. Another issue that needs to be raised is the necessity to adhere to the principle of accountability.

of the powers conferred by Article 58(2)(i) of Regulation 2016/679, has the authority to impose an administrative fine in accordance with Article 83 of Regulation 2016/679, depending on the circumstances of the specific case.

Taking into account the findings of the factual state, the President of the Personal Data Protection Office, utilizing the powers granted to him, has determined that the imposition of an administrative fine is warranted due to the failure of the Administrator to implement adequate measures to ensure compliance with the principles of data protection as outlined in the aforementioned regulation.

The assessment of the amount of the administrative fine is based on several factors, including the

nature, gravity, and duration of the infringement, the intentional or negligent character of the infringement, any actions taken by the Administrator to mitigate the damage suffered by data subjects, the degree of responsibility of the Administrator, any previous infringements by the Administrator, the degree of cooperation with the supervisory authority, and the categories of personal data affected by the infringement.

In light of these considerations, the President of the Personal Data Protection Office has concluded that the Administrator's actions constituted a serious violation of the principles of data protection, particularly regarding the confidentiality of personal data, which resulted in a significant risk to the rights and freedoms of the data subjects involved.

Consequently, the amount of the administrative fine has been set at a level that reflects the severity of the infringement while also taking into account the need to deter similar conduct in the future. The fine is intended not only to penalize the Administrator for the specific infringement but also to promote compliance with data protection regulations and to ensure the protection of personal data in the future.

The decision to impose this fine has been made in accordance with the principles of proportionality and necessity, ensuring that the penalty is appropriate to the circumstances of the case and serves the purpose of reinforcing the importance of data protection compliance.

In conclusion, the President of the Personal Data Protection Office has determined that the imposition of an administrative fine is justified and necessary to uphold the principles of data protection as established by Regulation 2016/679.

from the right granted to him under the provision of Regulation 2016/679 mentioned above, stated that in the case at hand, there were grounds justifying the imposition of an administrative monetary penalty on X.

According to Article 83(4)(a) of Regulation 2016/679, violations of the provisions concerning the obligations of the controller and the processor, as referred to in Articles 8, 11, 25-39, and 42 and 43, are subject to an administrative monetary penalty of up to EUR 10,000,000, or in the case of an enterprise, up to 2% of its total worldwide annual turnover from the previous financial year, with the higher amount applicable.

According to Article 83(5)(a) of Regulation 2016/679, violations of the provisions concerning the fundamental principles of processing, including the conditions for consent, as referred to in Articles 5, 6, 7, and 9, are subject to an administrative monetary penalty of up to EUR 20,000,000, or in the case of an enterprise, up to 4% of its total worldwide annual turnover from the previous financial year, with the higher amount applicable.

Article 83(3) of Regulation 2016/679 states that if the controller or processor intentionally or unintentionally violates several provisions of this regulation within the same or related processing operations, the total amount of the administrative monetary penalty shall not exceed the amount of the penalty for the most serious violation.

In this case, the administrative monetary penalty imposed on the Administrator was for violating Article 25(1) and Article 32(1) and (2) of Regulation 2016/679 based on the aforementioned Article 83(4)(a) of Regulation 2016/679, while for the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679 – based on Article 83(5)(a) of that regulation. At the same time, the penalty imposed on the Administrator for the violation of all the above provisions – in accordance with Article 83(3) of Regulation 2016/679 – does not exceed the amount of the penalty for the most serious violation identified in this case, namely the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679, which, according to Article 83(5)(a) of Regulation 2016/679, is subject to an administrative monetary penalty of up to EUR 20,000,000, or in the case of an enterprise – up to 4% of its total worldwide annual turnover from the previous financial year.

In deciding to impose an administrative monetary penalty, the President of UODO – in accordance with the provisions of Article 83(2)(a) - (k) of Regulation 2016/679 – took into account the following circumstances of the case, which necessitate the application of this type of sanction in the present

case and which have an aggravating effect on the amount of the imposed administrative monetary penalty:

1. The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing, the number of affected individuals whose data is concerned, and the extent of the damage suffered by them (Article 83(2)(a) of Regulation 2016/679). The aggravating nature of the discussed criterion arises primarily from the fact that the violated provisions of Regulation 2016/679 define the fundamental obligations of the Administrator. The violation of the principle referred to in Article 5(1)(f) of Regulation 2016/679 means that X. failed to implement adequate technical and organizational measures, which has a direct impact on the possibility of materializing the risk of infringement of the rights or freedoms of individuals whose personal data X. processed. Similarly, the violation of the accountability principle resulting from Article 5(2) of Regulation 2016/679 is associated with the violation of fundamental obligations by the Administrator. Non-compliance with this principle is linked to the uncertainty of individuals and lowers the level of trust these individuals have in X. It should be emphasized that the nature and gravity of the violation of Article 5(1)(f) and Article 5(2) of Regulation 2016/679 is serious also because the violation of the aforementioned provisions is subject to the possible maximum administrative monetary penalty – of up to EUR 20,000,000.

The violation of Article 25(1) of Regulation 2016/679 is also serious, as this provision imposes on the Administrator the obligation to adopt a proactive approach to data protection issues. It should also be noted the importance of the norms resulting from Articles 32(1) and (2) of Regulation 2016/679, as these legal provisions indicate the necessity of implementing adequate technical and organizational measures to ensure a level of security corresponding to the risk of infringement of the rights or freedoms of individuals.

In light of the above, it should be noted that the violation of these provisions is also serious and of significant weight.

The identified violation of data protection provisions in this case, which resulted in the possibility of unauthorized access to the data processed by the Administrator by an unauthorized person or persons, and consequently the possibility of obtaining personal data of individuals cooperating with the Administrator and individuals using the leisure activities organized by X. (including their parents or guardians), is of significant weight and serious nature, as it creates a high risk of negative legal consequences for the individuals whose data could have been accessed by unauthorized persons.

The Administrator's failure to comply with the obligation to implement security measures to protect the processed data from being disclosed to unauthorized persons not only entails a potential but also a real possibility of these data being used by third parties without the knowledge and against the will of the individuals to whom the data pertains, in violation of the provisions.

Regulation 2016/679, e.g., for the purpose of establishing legal relationships or incurring obligations on behalf of the individuals whose data has been obtained. The Statute (...) [2] indicates that (...). From the above-mentioned provisions of the statute, it follows that X. carries out significant activities for the upbringing of children and youth, and therefore should apply high standards of organizational culture, including those concerning the security of processed personal data. Information on the organization's website indicates that in 2023, W. had (...) individuals [3]. Meanwhile, in such an important organization – from the perspective of its educational character – there is a violation of personal data protection regulations. The circumstances of the violation of personal data protection regulations (detailed above) not only create a negative image of the Administrator but also indicate this organization's dismissive attitude towards the issue of personal data protection, as the documents adopted by X. regulating the process of personal data processing have only a formal value, rendering them practically useless regulations that do not ensure security for the personal data processing process. It should also be emphasized that the duration of the violation of the provisions of Regulation 2016/679 is long, as it should be assumed that the violation began on May 25, 2018, i.e., on the day the Regulation 2016/679 came into effect, and ended only after the withdrawal of laptops lacking encrypted storage, which occurred after the personal data breach reported to the President of UODO on May 17, 2023 (with respect to the violation of the obligation to implement adequate organizational

and technical measures ensuring security in the process of personal data processing using portable data carriers). In turn, in the case of the violation of the obligation to implement regular testing, measuring, and assessing the effectiveness of technical and organizational measures aimed at ensuring the security of personal data processed using portable computers, the violation of personal data protection regulations continues. The violation of personal data protection regulations identified in this case concerned all individuals whose personal data the Administrator processes. In this case, there is no evidence that the individuals whose data was accessed by unauthorized person(s) suffered material damage. Nevertheless, the mere violation of the confidentiality of their data constitutes non-material damage (harm); individuals whose data was unlawfully obtained may at least feel apprehensive about losing control over their personal data, identity theft, or identity fraud, discrimination, or finally, financial loss. Furthermore, until the issuance of this decision, the lost laptop has not been found, so unauthorized person(s) may still have access to the personal data contained on that device. As indicated by the District Court in Warsaw in the judgment of August 6, 2020, case file XXV C 2596/19, apprehension, and thus the loss of security constitutes a real non-material damage associated with the obligation to remedy it. Furthermore, the Court of Justice of the EU in the ruling of December 14, 2023, in the case of Natsionalna agentsia za prihodite (C-340/21) emphasized that "Article 82(1) of the GDPR should be interpreted in such a way that the apprehension of potential misuse of personal data by third parties, which a person whose data is concerned experiences as a result of a breach of this regulation, may in itself constitute 'non-material damage' within the meaning of this provision."

2. Intentional nature of the violation (Article 83(2)(b) of Regulation 2016/679). According to the Guidelines of the Article 29 Data Protection Working Party on the application and determination of administrative fines for the purposes of Regulation No. 2016/679 (hereinafter referred to as WP Guidelines 253) confirmed by the Guidelines 04/2022 on calculating administrative fines based on the GDPR (hereinafter referred to as Guidelines 04/2022 [4]), intent "includes both knowledge and deliberate action, in connection with the characteristics of the prohibited act." The Administrator made a conscious decision to use portable computers in a manner that does not guarantee security when taken outside the organization's premises. The Administrator was aware of how personal data should be processed on portable computers issued to employees/volunteers to ensure appropriate security, including protection against unauthorized or unlawful processing, using appropriate technical and organizational measures, and thus how to comply with the principle of "integrity and confidentiality" expressed in Article 5(1)(f) of Regulation 2016/679. In the risk analysis conducted, the Administrator correctly identified the threats and assessed the level of risk as acceptable (assuming that the planned technical and organizational measures such as disk encryption of laptops were implemented). However, he did not implement the security measures specified in his risk analysis, i.e., encrypting the hard drives of the computers, and took real action only after the violation occurred. The Administrator's actions demonstrated awareness of the necessity to implement adequate safeguards when processing personal data using portable computers. Therefore, the Administrator was aware that during the period from the identification of the threat to its materialization, he did not ensure an appropriate level of security for personal data processed on the computer, which would constitute a violation of personal data protection regulations. Thus, intentionally violated the provisions of Article 5(1)(f) of Regulation 2016/679 in conjunction with Article 25(1) and Article 32(1) and (2) of Regulation 2016/679, and consequently also Article 5(2) of Regulation 2016/679.

Considering the findings in the case subject to the resolution of this decision, it should be stated that the Administrator – despite being aware – committed omissions resulting in violations of the aforementioned provisions of Regulation 2016/679. Thus, this constitutes a significant circumstance affecting the severity of the administrative monetary penalty.

3. Categories of personal data affected by the violation (Article 83(2)(g) of Regulation 2016/679). The personal data that were on the lost media constitute data subject to special protection under Article 9(1) of Regulation 2016/679. This imposes on the administrators of this data the obligation to treat this

information with particular care, also due to the possible negative consequences for the individuals to whom this data pertains, in the event of its disclosure to unauthorized persons, including discrimination or loss of reputation. Furthermore, the fact that there was a breach of the confidentiality of personal data in terms of: surnames and first names, parents' names, date of birth, bank account number, residential or stay address, PESEL identification number, email address, data concerning earnings and/or owned assets, series and number of the identity card, phone number, other (membership in an association, official assignment) indicates a high risk of violation of the rights or freedoms of natural persons.

The PESEL number, which is an eleven-digit numerical symbol that uniquely identifies a natural person, containing the date of birth, ordinal number, gender designation, and control number, is thus closely linked to the private sphere of the individual and is also subject, as a national identification number, to exceptional protection under Article 87 of Regulation 2016/679. It is a data of a special nature and requires such special protection. There is no other, so specific data that would unequivocally identify a natural person. It is not without reason that the PESEL number serves as an identifying data for every individual and is widely used in dealings with various institutions and in legal circulation. The PESEL number, along with the first name and surname, uniquely identifies a natural person in a way that allows negative consequences of the violation (e.g., identity theft, loan fraud) to be attributed to that specific individual.

In this context, it is worth citing the EDPB Guidelines 04/2022, which state: "Regarding the requirement to consider the categories of personal data affected by the breach (Article 83(2)(g) of the GDPR), the GDPR explicitly indicates the types of data that are subject to special protection, and thus a more stringent response when imposing monetary penalties. This applies at least to the types of data covered by Articles 9 and 10 of the GDPR, as well as data not covered by the scope of these articles, the dissemination of which immediately causes harm or discomfort to the individual to whom the data pertains (e.g., location data, private communication data, national identification numbers, or financial data such as transaction statements or credit card numbers). Generally speaking, the more categories of such data are involved in the breach or the more sensitive the data, the greater weight the supervisory authority may assign to this factor. The quantity of data concerning each individual to whom the data pertains is also significant, as the scale of the breach of the right to privacy and personal data protection increases with the amount of data concerning each individual."

It is also worth noting the developing case law in this area, where, for example, in the judgment of November 15, 2022, case file II SA/Wa 546/22, the Administrative Court in Warsaw stated: "It was also obvious that the authority, when determining the penalty, had to take into account the fact that the breach concerned data of great sensitivity (including PESEL, address, health status data)." This view was also shared by the aforementioned Court in the judgment of June 21, 2023, in case file II SA/Wa 150/23, where the Administrative Court in Warsaw stated: "In summary, the Court holds that the disclosure of the PESEL number indicates a high risk of violation of the rights or freedoms of natural persons."

In determining the amount of the administrative monetary penalty, the President of the UODO considered as a mitigating circumstance, which influenced the reduction of the imposed penalty, the good cooperation of the Administrator with the supervisory authority undertaken and conducted to eliminate the violation and mitigate its possible negative effects (Article 83(2)(f) of Regulation 2016/679). The Administrator also conducted a re-assessment of the risk after the occurrence of the data protection breach in question, in which vulnerabilities related to the loss of data carriers, including laptops, were taken into account.

In the opinion of the President of the UODO, the execution of the aforementioned actions should be regarded as a mitigating circumstance affecting the reduction of the imposed penalty.

Other circumstances, as indicated below, referred to in Article 83(2) of Regulation 2016/679, after assessing their impact on the established violation in this case, were deemed by the President of the UODO to be neutral in his assessment, meaning that they had neither an aggravating nor a mitigating

effect on the amount of the imposed administrative monetary penalty.

1. Actions taken to minimize the damage suffered by the individuals to whom the data pertains (Article 83(2)(c) of Regulation 2016/679). In the context of this criterion, the purpose of the Administrator's action is significant, namely to minimize the damage suffered by the individuals to whom the data pertains. The President of the UODO did not record any such actions by the Administrator in this case. The Administrator only performed...

****Obligation to Notify Individuals of Personal Data Breaches****

Resulting from Article 34(1) of Regulation 2016/679. The mere provision of information to the individuals concerned about the incident cannot be considered as an action aimed at minimizing the damage suffered by those individuals in this case.

1. **Degree of Responsibility of the Administrator**

Taking into account the technical and organizational measures implemented by him pursuant to Articles 25 and 32 (Article 83(2)(d) of Regulation 2016/679). The President of UODO found that the Administrator violated the provisions of Articles 25(1), 32(1) and (2) of Regulation 2016/679. In his assessment, the Administrator bears a high degree of responsibility for failing to implement appropriate technical and organizational measures that would have prevented the breach of personal data protection. It is evident that in the context considered, regarding the nature, purpose, and scope of personal data processing, the Administrator did not "do everything that could have been expected of him"; thus, he did not fulfill the obligations imposed on him by Articles 25 and 32 of Regulation 2016/679. However, in this case, this circumstance constitutes the essence of the breach itself; it is not merely a factor influencing – either mitigating or aggravating – its assessment. For this reason, the lack of appropriate technical and organizational measures referred to in Articles 25 and 32 of Regulation 2016/679 cannot be recognized by the President of UODO in this case as a circumstance that could additionally influence a stricter assessment of the breach and the amount of the administrative fine imposed on X.

2. **Any Relevant Previous Breaches by the Administrator or Processor**

(Article 83(2)(e) of Regulation 2016/679). The President of UODO did not find any previous breaches of personal data protection regulations committed by the Administrator, therefore there are no grounds to treat this circumstance as aggravating. It is the duty of every administrator to comply with legal regulations (including those on personal data protection), so the absence of previous breaches cannot be a mitigating circumstance when imposing sanctions.

3. **The Manner in Which the Supervisory Authority Became Aware of the Breach**

(Article 83(2)(h) of Regulation 2016/679). The President of UODO found a breach of the provisions of Regulation 2016/679 as a result of a notification of a personal data breach made by the Administrator. By making this notification, the Administrator was merely fulfilling a legal obligation, and there are no grounds to consider this circumstance as mitigating. According to Guidelines 04/2022, "(...) when assessing this aspect, particular importance can be attributed to the question of whether the administrator or processor notified of the breach on their own initiative, and if so, to what extent, before the supervisory authority was informed of the breach through – for example – a complaint or investigation. This circumstance is irrelevant when the administrator is subject to specific obligations regarding breach notifications (such as the obligation to notify a personal data breach specified in Article 33). In such cases, the fact of making a notification should be considered a neutral circumstance (...)"

4. **Compliance with Previously Applied Measures in the Same Case**

Referred to in Article 58(2) of Regulation 2016/679 (Article 83(2)(i) of Regulation 2016/679). Prior to issuing this decision, the President of UODO did not apply any measures listed in Article 58(2) of Regulation 2016/679 against the Administrator in the case at hand, therefore the administrator had no obligation to take any actions related to their application, which, if assessed by the President of UODO, could have had an aggravating or mitigating impact on the assessment of the established breach.

5. **Application of Approved Codes of Conduct under Article 40 of Regulation 2016/679 or Approved

Certification Mechanisms under Article 42 of Regulation 2016/679**

(Article 83(2)(j) of Regulation 2016/679). The Administrator does not apply approved codes of conduct or approved certification mechanisms referred to in the provisions of Regulation 2016/679. However, their adoption, implementation, and application are not mandatory for administrators and processors, as stipulated by the provisions of Regulation 2016/679, therefore the circumstance of their non-application cannot be considered against the Administrator in this case. Conversely, the circumstance of adopting and applying such instruments could be taken into account in favor of the Administrator, as measures guaranteeing a higher than standard level of protection for processed personal data.

6. **Financial Benefits Achieved Directly or Indirectly in Connection with the Breach or Losses Avoided**

(Article 83(2)(k) of Regulation 2016/679). The President of UODO did not find that the Administrator derived any financial benefits or avoided such losses in connection with the breach. Therefore, there are no grounds to treat this circumstance as aggravating for the administrator. The existence of measurable financial benefits resulting from the breach of the provisions of Regulation 2016/679 should be assessed very negatively. On the other hand, the Administrator's failure to achieve such benefits, as a natural state independent of the breach and its consequences, is a circumstance that inherently cannot be mitigating for the Administrator. This is confirmed by the very wording of Article 83(2)(k) of Regulation 2016/679, which requires the supervisory authority to pay due attention to the benefits "achieved" – that is, those that occurred on the part of the entity committing the breach.

8. Other aggravating or mitigating factors (Article 83(2)(k) of Regulation 2016/679). The President of the UODO, thoroughly considering the case, did not note any circumstances other than those described above that could influence the assessment of the violation and the amount of the imposed administrative monetary penalty.

In the opinion of the President of the UODO, the administrative monetary penalty applied fulfills, in the established circumstances of this case, the functions referred to in Article 83(1) of Regulation 2016/679, i.e., it is effective, proportionate, and deterrent in this individual case.

Taking into account all the circumstances discussed above, the President of the UODO concluded that the imposition of an administrative monetary penalty on the Administrator is necessary and justified by the seriousness, nature, and scope of the violations of the provisions of Regulation 2016/679 attributed to this entity. It should be noted that the application of any other corrective measure provided for in Article 58(2) of Regulation 2016/679, particularly merely issuing a reprimand (Article 58(2)(b) of Regulation 2016/679), would not be proportionate to the identified irregularities in the processing of personal data and would not guarantee that the aforementioned entity would not commit similar neglects in the future, as in this case.

Regarding the amount of the administrative monetary penalty imposed on X., it should be noted that the Administrator does not belong to the group of entities listed in Article 102(1) and (2) of the Act on the Protection of Personal Data (u.o.d.o.), and therefore, in this case, the limitations on the amount of the administrative monetary penalty (respectively up to 10,000 or 100,000 PLN) do not apply. Consequently, in accordance with Article 101 of the u.o.d.o., the administrative monetary penalty is imposed on X. based on and under the conditions specified in Article 83 of Regulation 2016/679.

According to the provisions of Article 103 of the u.o.d.o., the amounts expressed in euros referred to in Article 83 of Regulation 2016/679 are calculated in zlotys according to the average euro exchange rate announced by the National Bank of Poland in the exchange rate table on January 28 of each year, and in the event that the National Bank of Poland does not announce the average euro exchange rate on January 28 of a given year – according to the average euro exchange rate announced in the nearest exchange rate table of the National Bank of Poland after that date.

Having the above in mind, the President of the UODO, based on Article 83(5)(a) in conjunction with Article 103 of the u.o.d.o., for the violation described in the operative part of this decision, imposed on X. – applying the average euro exchange rate from January 29, 2024 (1 EUR = 4.3653 PLN) – an

administrative monetary penalty in the amount of 24,555 PLN (which is equivalent to 5,625 EUR).

In the opinion of the President of the UODO, the monetary penalty of 24,555 PLN (in words: twenty-four thousand five hundred fifty-five zlotys) meets the criteria referred to in Article 83(1) of Regulation 2016/679 in the established circumstances of this case due to the seriousness of the identified violation in the context of the fundamental purpose of Regulation 2016/679 – the protection of fundamental rights and freedoms of natural persons, in particular the right to the protection of personal data. Referring to the amount of the administrative monetary penalty imposed on X., the President of the UODO considered it proportional to the financial situation of the Administrator and that it would not constitute an excessive burden for him.

The information provided by the Administrator indicates that the total annual turnover from the previous financial year in 2023 from conducting business activity amounted to (...) PLN ((...) EUR), which means that the amount of the administrative monetary penalty imposed in this case constitutes approximately (...) % of the aforementioned revenue. At the same time, it is worth emphasizing that the amount of the imposed penalty is only about 0.03 % of the maximum penalty that the President of the UODO could – applying the static maximum penalty of up to 20,000,000 EUR in accordance with Article 83(5) of Regulation 2016/679 – impose on X. for the violations identified in this case.

The amount of the penalty has been set at such a level that, on the one hand, it constitutes an adequate response from the supervisory authority to the degree of violation of the Administrator's obligations, while on the other hand, it does not create a situation in which the necessity to pay the financial penalty would lead to negative consequences in the form of a significant burden for the Administrator. In the opinion of the President of the UODO, the Administrator should and is able to bear the consequences of his neglect in the area of data protection, as evidenced by the financial report of X. for 2023.

Finally, it is necessary to indicate that in determining the amount of the administrative monetary penalty in this case, the President of the UODO applied the methodology adopted by the European Data Protection Board in Guidelines 04/2022. According to the guidance presented in this document:

1. The President of the UODO categorized the violations of the provisions of Regulation 2016/679 identified in this case (see Chapter 4.1 of Guidelines 04/2022). The violations of personal data protection regulations identified in this case belong to both the category of violations subject to a penalty of up to 10,000,000 EUR, and in the case of an enterprise – up to 2% of its total annual worldwide turnover from the previous financial year, with the higher amount applying, as well as to the category of violations subject to a penalty of up to 20,000,000 EUR, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount applying.

The most serious violation identified in this case, i.e., the violation of Article 5(1)(f) and (2) of Regulation 2016/679 – in accordance with Article 83

Art. 5 lit. a) of Regulation 2016/679 – is subject to an administrative fine of up to 20,000,000 EUR, and in the case of an enterprise – up to 4% of its total annual worldwide turnover from the previous financial year, with the higher amount being applicable. It has therefore been recognized in abstracto (irrespective of the individual circumstances of the specific case) by the EU legislator as more serious than the violations indicated in Article 83(4) of Regulation 2016/679.

2. The President of the UODO assessed the violations identified in this case as violations of a high level of seriousness (see Chapter 4.2 of Guidelines 04/2022). In this assessment, the criteria from Article 83(2) of Regulation 2016/679 that pertain to the subject matter of the violations (which constitute the "seriousness" of the violation) were taken into account, namely: the nature, gravity, and duration of the violations (Article 83(2)(a) of Regulation 2016/679), the intentional or unintentional nature of the violations (Article 83(2)(b) of Regulation 2016/679), and the categories of personal data affected by the violations (Article 83(2)(g) of Regulation 2016/679). A detailed assessment of these circumstances has been presented above. It should be noted that considering their cumulative impact on the assessment of the violations identified in this case treated in their entirety leads to the

conclusion that the level of their seriousness is also high in concreto (on the scale of seriousness of violations presented in point 60 of Guidelines 04/2022). Consequently, this leads to the acceptance – as the starting amount for calculating the fine – of a value within the range of 20% to 100% of the maximum fine that can be imposed on X. Given that Article 83(5) of Regulation 2016/679 obliges the President of the UODO to adopt as the maximum amount of the fine for the violations indicated in this provision the amount of 20,000,000 EUR or – if this amount is higher than 20,000,000 EUR – the amount representing 4% of X's turnover from the previous financial year, the President of the UODO concluded that the so-called static maximum amount of the fine, i.e., 20,000,000 EUR, is applicable in this case. Having at his disposal a range from 0 to 20,000,000 EUR, the President of the UODO adopted, as adequate and justified by the circumstances of the case, the starting amount for calculating the fine of 6,000,000 EUR (representing 30% of the static maximum amount of the fine).

3. In accordance with point 66 of Guidelines 04/2022 (in relation to enterprises whose annual turnover is between 0 EUR and 2,000,000 EUR), the President of the UODO deemed it appropriate to take advantage of the possibility to reduce the starting amount based on the assessment of the seriousness of the violation to the amount of 15,000 EUR.

4. The President of the UODO assessed the impact on the identified violation of other circumstances (besides those considered above in the assessment of the seriousness of the violation) indicated in Article 83(2) of Regulation 2016/679 (see Chapter 5 of Guidelines 04/2022). These circumstances, which may have an aggravating or mitigating effect on the assessment of the violation, relate – as assumed by Guidelines 04/2022 – to the subjective side of the violation, that is, to the entity itself that committed the violation and to its behavior before the violation, during it, and after its occurrence. A detailed assessment and justification of the impact of each of these criteria on the assessment of the violation have been presented above. The President of the UODO concluded (which was justified in the above part of the reasoning of the decision) that the circumstances having a mitigating effect on the amount of the fine are the degree of cooperation with the supervisory authority in order to remedy the violation and mitigate its potential negative effects (Article 83(2)(f) of Regulation 2016/679). The remaining criteria (from Article 83(2)(c), (d), (e), (h), (i), (j), (k) of Regulation 2016/679) – as indicated above – did not have an impact, either mitigating or aggravating, on the assessment of the violation and consequently on the imposition of the fine. Due to the existence of additional aggravating and mitigating circumstances related to the subjective side of the violations, the President of the UODO deemed it appropriate to reduce the amount of the fine to 11,250 EUR.

5. The President of the UODO stated that the amount of the administrative fine determined in the manner presented above does not exceed – in accordance with Article 83(3) of Regulation 2016/679 – the legally defined maximum amount of the fine provided for the most serious violation (see Chapter 6 of Guidelines 04/2022).

6. Despite the fact that the amount of the fine determined according to the above principles does not exceed the legally defined maximum fine, the President of the UODO considered that it requires additional adjustment due to the principle of proportionality mentioned in Article 83(1) of Regulation 2016/679 as one of the three directives for imposing a fine (see Chapter 7 of Guidelines 04/2022). Undoubtedly, a fine of 11,250 EUR would be an effective fine (due to its severity, it would achieve its punitive purpose, which is to punish unlawful behavior) and deterrent (allowing effectively to dissuade both X and other administrators from committing violations of the provisions of Regulation 2016/679 in the future). However, such a fine would be – in the opinion of the President of the UODO – a disproportionate penalty both in relation to the seriousness of the identified violations (which in abstracto and in concreto is low – see points 1 and 2 above) and due to its excessive – in relation to this seriousness – severity. The principle of proportionality requires, among other things, that the measures adopted by the administrative authority do not exceed what is appropriate and necessary to achieve legitimate objectives (see points 137 and 139 of Guidelines 04/2022). In other words: "A sanction is proportional if it does not exceed the threshold of severity defined by taking into account... "circumstances of the specific case"

(P. Litwiński (ed.), Regulation (EU) 2016/679 of the European Parliament and of the Council of April

27, 2016 [...]; Commentary on Article 83 [in:] P. Litwiński (ed.) General Data Protection Regulation. Data Protection Act. Selected Sectoral Provisions. Commentary).

Taking into account the principle of proportionality of the penalty, the President of the UODO further reduced the amount of the fine to 5,625 EUR (equivalent to 24,555.00 PLN). In his opinion, such determination of the final amount of the imposed fine will not affect its effectiveness and deterrent character. This amount constitutes a threshold above which any further increase in the amount of the fine will not be associated with an increase in its effectiveness and deterrent character. On the other hand, a greater reduction in the amount of the fine could come at the expense of its effectiveness and deterrent character, as well as a coherent understanding, application, and enforcement of Regulation 2016/679 in relation to other supervisory authorities and the EDPB, as well as the principle of equal treatment of entities in the EU and EEA internal market.

In summary, in the opinion of the President of the UODO, the administrative fine imposed in this case against the Administrator meets, in light of the overall individual circumstances of the case, the criteria (functions of penalties) referred to in Article 83(1) of Regulation 2016/679, due to the seriousness of the identified violations in the context of the fundamental requirements and principles of Regulation 2016/679 – especially the principle of confidentiality expressed in Article 5(1)(f) of Regulation 2016/679.

In this factual and legal context, the President of the Personal Data Protection Office ruled as stated in the operative part.

[1] Act of May 10, 2018 on the Protection of Personal Data (Journal of Laws of 2019, item 1781), hereinafter referred to as the u.o.d.o.

[2] (...)

[3] (...)

[4] https://edpb.europa.eu/system/files/2024-01/edpb_guidelines_042022_calculationofadministrativefines_pl

Print article

Metadata

Provider:

Department of Control and Violations

Information created by:

Mirosław Wróblewski

2024-11-12

Information entered by:

Wioletta Golańska

2024-12-02 12:46:16

Last modified by:

Karolina Jastalska

2024-12-02 16:32:29